

PRESIDIO — Secure Development Lifecycle

Public report on governance, quality, security, and supply-chain posture

2026-10-08 — Version 1.3

Executive summary

The PRESIDIO *hardened-** product family is developed under a documented Secure Software Development Lifecycle (SDLC) whose goal is to make every claim about quality, security, and privacy auditable from the source tree alone. The framework is self-attested — PRESIDIO is not pursuing formal certification at this stage — but every control cites the evidence that substantiates it (tests, CI jobs, release artefacts, policies), so a reviewer can independently verify the posture without access to private systems.

This report summarises the lifecycle at a level appropriate for customers and partners who need to understand how PRESIDIO software is built, verified, released, and operated. It is a living document, reviewed quarterly (§3.2). The full framework is authored and versioned inside the flagship product that runs as a PRESIDIO-operated service (`presidio-hardened-x402`); every other repository states which baseline applies to it, and the family-wide mapping is published in `applicability.md`.

1. Scope

The lifecycle defines **two baselines**, distinguished by how and where the software runs, not by the language or package format:

- **Open-source baseline.** Applies to every `presidio-hardened-*` package published on PyPI (and equivalent registries) under a permissive open-source licence. Provides the verifiable basics: CI with tests and coverage, lint, a CodeQL pass, a dependency audit, Dependabot, a documented security-disclosure path, and a SECURITY.md policy. The repository is the single source of truth; every control cites its own evidence (a workflow, a config, a test).
- **Commercial-operated baseline.** Adds the full framework on top of the open-source baseline: STRIDE + LINDDUN GO threat modelling, OWASP ASVS 5.0 L2 verification (L3 aspirational for authentication and cryptography), an adversary-chain release gate, SLSA v1.2 Build L3 provenance, Sigstore keyless signing, CycloneDX SBOMs, a DPIA, SLOs and an incident-response policy. This baseline applies to:
 - services operated by PRESIDIO inside PRESIDIO-controlled EU infrastructure (today: the x402 screening service at `screen.presidio-group.eu`, live since April 2026);
 - deployments delivered to paying customers under contract, whether or not the underlying code is also published on PyPI;
 - any codebase that processes personal data or handles payments on PRESIDIO's behalf.

The same source tree can appear in either tier — the tier is set by how the code is run, not by the repository it lives in. Customers running the open-source libraries inside their own infrastructure

are responsible for applying controls appropriate to their own risk profile; PRESIDIO documents the interfaces and provides the primitives.

The rest of this report describes the full framework. Sections that apply only to the commercial-operated baseline are flagged (*commercial-operated*); all other sections apply to both tiers.

Excluded from scope: downstream customers' own applications, third-party services a customer chooses to integrate, and end-user asset custody arrangements.

2. Alignment stance

Documented alignment, not certification. All conformance claims are self-attested. Every claim links to evidence inside the product repository — a test, a CI job definition, a workflow artefact, a signed release, or a policy file. External review is invited through each product's published security policy.

PRESIDIO anchors its practice to a curated set of international standards and industry frameworks. No single framework is used in isolation; they are combined so that each lifecycle phase has a well-defined control catalogue.

Tier	Framework	Role
Anchor	NIST Secure Software Development Framework (SSDF, SP 800-218)	Catalogue of secure-SDLC practices (PO / PS / PW / RV)
Anchor	ISO/IEC 25010:2023	Product quality model (nine characteristics)
Anchor	ISO/IEC/IEEE 29148:2018	Requirements engineering; RFC 2119 language; traceability
Overlay	OWASP ASVS 5.0	Application-security verification; L2 baseline for the commercial-operated tier, L3 aspirational for authentication and cryptography in PRESIDIO-operated services
Overlay	LINDDUN GO	Privacy-threat modelling (EU-origin, PII-centric)
Overlay	SLSA v1.2	Build-time supply-chain integrity; Build Level 3
Overlay	OpenSSF Scorecard	Automated open-source posture checks; score ≥ 7.0
Reference	ISO/IEC 27001:2022 Annex A 8.25–8.34	Secure development controls (the 2013 edition's Annex A.14)
Reference	ISO/IEC 27034-1, ISO/IEC 29100	Application-security and privacy concepts
Legal	GDPR Art. 25 (privacy by design), Art. 35 (DPIA)	Regulatory anchor

Frameworks explicitly out of scope: BSIMM (benchmarking tool), ISO/IEC 12207 (too broad),

ISO/IEC 27701 (certification-oriented), NIST SP 800-53 / 800-161, and SOC 2. A SOC 2 programme is a later-phase goal tied to a paid-tier launch, not a current commitment.

3. Governance

3.1 Document set

The **commercial-operated** baseline carries a full SDLC document set inside the product’s repository, covering charter and scope, quality model, requirements register, architecture, threat model, verification strategy, supply-chain posture, operations runbooks, governance policy, a traceability matrix, a framework-alignment table, a risk register, a Data Protection Impact Assessment (DPIA) where personal data is handled, and an Architecture Decision Record (ADR) log.

Repositories on the **open-source baseline** do not carry that set. Each one states its tier in its `SECURITY.md` and points to the workflows that provide its controls; `applicability.md` lists every public repository with its tier and the controls measured for it. A repository moves up a tier when it starts running as a PRESIDIO-operated service, is delivered to a paying customer, or starts handling personal data or payments on PRESIDIO’s behalf.

Every document in the full set carries structured metadata: identifier, version, last-reviewed date, next-review date, and the framework editions that applied at last review. This makes cadence failures visible and framework drift detectable.

3.2 Review cadence

Artefact class	Cadence	Trigger
Static SDLC documents (charter, quality, architecture, threat model, etc.)	Annual	Next-review date or major product change
Governance, risk register, DPIA, framework alignment	Quarterly	Next-review date
Data-category inventory	Event-driven	Automated drift detection in CI
Architecture Decision Records	Event-driven	One per non-trivial or structural decision
Threat-model re-walk	Annual, or on any new trust-boundary crossing	New component or material change
Framework-edition deltas	Quarterly	Publisher announces a new edition

3.3 Change management

Every change is classified as *trivial*, *minor*, *non-trivial*, or *structural*. Non-trivial and structural changes require a dedicated ADR committed in the same pull request and an update to the traceability matrix. ADRs follow the Nygard template (Context / Decision / Consequences / Status), are numbered monotonically, and are never amended — a change of mind creates a new ADR that supersedes the old one.

4. Quality

The product quality model implements ISO/IEC 25010:2023. Each of the nine characteristics is assigned a measurable target per component profile, and each target is linked to a non-functional requirement in the requirements register.

Characteristic	Example targets
Functional suitability	100 % of MUST requirements have passing acceptance tests
Performance efficiency	Per-profile latency and throughput budgets with published measurements
Compatibility	Frozen wire contracts; end-to-end contract tests that break on drift
Interaction capability	Short integration path for library users; stable structured error envelope for the service
Reliability	100 % test-pass on main; ≥ 90 % line coverage; fault-tolerant client retry; persistent service state
Security	See §5
Maintainability	Modularity limits, lint and type-check gates, ADRs for every non-trivial change
Flexibility	Pluggable adapters; 12-factor configuration; broad Python-version support
Safety	Not applicable at current scope; re-assessed annually

Functional and non-functional requirements are written in ISO/IEC/IEEE 29148 form with RFC 2119 keywords. Each requirement has a stable identifier that flows through the traceability matrix to threats, controls, tests, and metrics.

5. Security

5.1 Threat modelling

Security threats are modelled with STRIDE across all components. Privacy threats are modelled with LINDDUN GO. Both matrices are maintained inside the repository alongside the architecture document that defines the trust boundaries they analyse.

Every identified threat is mapped to at least one mitigation; every non-trivial mitigation is linked to a test, a runbook, or an explicit accepted-residual-risk entry in the risk register.

5.2 Adversary-chain release gate (*commercial-operated*)

Beyond per-control testing, each commercial-operated product maintains a curated set of end-to-end *adversary chains* — realistic attack sequences that exercise multiple controls in concert. A release is blocked unless every chain is in one of three explicit states:

State	Meaning
Closed	Threat mitigated; the mitigation is asserted by a dedicated test

State	Meaning
Waived (time-boxed)	Residual risk accepted with a documented expiry date
Transferred	Responsibility explicitly shifted to the operator with a documented runbook

No chain may remain in state *open* or *unassessed* at release.

5.3 Verification (*commercial-operated*)

Verification targets OWASP ASVS 5.0.0 Level 2 for commercial-operated products; open gaps against that target are listed with their remediation dates in the product’s verification record and risk register. Services operated by PRESIDIO additionally target Level 3 aspirationally for the two chapters where the bar is highest — Authentication (V6) and Cryptography (V11) — with every gap documented and tracked. The open-source baseline is covered by the subset of these controls that the automated release gate enforces in public CI.

The release gate aggregates:

- Lint, format, and type checks;
- Unit, integration, and contract tests;
- Line-coverage threshold;
- Dependency vulnerability audit;
- Secret scanning;
- Data-inventory drift check;
- ASVS checklist review;
- Adversary-chain status;
- Load test against a documented capacity target;
- Supply-chain artefacts (see §6);
- Governance housekeeping (changelog, DPIA, ADR, risk register).

6. Supply chain

Control	Mechanism	Tier
Build provenance	SLSA v1.2 Build Level 3 — hardened, isolated GitHub-hosted builds with non-forgable in-toto provenance attestations (signing identity inaccessible to build steps)	commercial-operated

Control	Mechanism	Tier
Artefact signing	Keyless signing via Sigstore for published packages; the release pipeline holds no long-lived key. Long-lived keys that do exist — tag-signing keys and service evidence-signing keys — are listed with their custody in the product’s risk register	commercial-operated
Publishing	Trusted Publishing from the build platform to the package registry — no API tokens stored	commercial-operated
Software Bill of Materials	CycloneDX v1.6 JSON, generated per release and attached to the release. Container-image SBOMs are planned	commercial-operated
Dependency pinning	Lockfile committed and enforced by a CI job (drift between the lockfile and the manifest fails the build); GitHub Actions pinned to commit SHAs on the hardened repositories; CI toolchain installs are not yet hash-pinned	both
Vulnerability gate	Automated dependency audit (pip-audit , cargo-deny) blocking unwaived Medium-or-higher findings. Commercial-operated: on every pull request. Open-source baseline: required; per-repository status, including gaps, in applicability.md	both
Automated updates	Dependency-update automation raises security and minor-version pull requests, each subject to the normal CI pipeline	both
Container images	Digest-pinned base images; non-root runtime; read-only root filesystem; no-new-privileges and all capabilities dropped. Image signing and provenance are planned, not yet in place	commercial-operated

Control	Mechanism	Tier
Posture score	OpenSSF Scorecard refreshed weekly on public repositories; target score ≥ 7.0 ; a dip is triaged into the risk register at the next review	both

Release tags are signed. Verification instructions for published packages are released alongside every release.

7. Operations

7.1 Service-level objectives (*commercial-operated*)

Objective	Target
Availability (free tier)	$\geq 99.5\%$ per calendar month
Steady-state request latency	p99 ≤ 100 ms at baseline load for the fast path
Error budget	$\leq 0.5\%$ 5xx per month
Mean time to remediate — critical security patch	≤ 7 days
Mean time to remediate — high-severity patch	≤ 30 days

Objective misses are triaged into the risk register at the next monthly review.

7.2 Incident response

Incidents are classified SEV-1 through SEV-4. Response is blameless, every incident produces a written record, and structural fixes are captured as Architecture Decision Records.

Severity	Acknowledge within	Mitigate within
SEV-1 Critical	1 hour	24 hours; public advisory within 72 hours
SEV-2 High	4 hours	7 days
SEV-3 Medium	1 day	30 days
SEV-4 Low	7 days	Next release

7.3 Coordinated vulnerability disclosure

Step	Commitment
Intake	Private advisory channel documented in each product's security policy
Acknowledgement	Within 5 business days
Patch target	Within 30 days of a confirmed vulnerability (shorter for SEV-1)
Advisory publication	Within 90 days of report, regardless of patch status (embargo resettable by mutual agreement)

Step	Commitment
Safe harbour	Good-faith research, respecting rate limits and own-installation testing, will not be pursued

8. Privacy and data protection

PRESIDIO treats privacy-by-design as a first-class property. Each commercial-operated product ships a Data Protection Impact Assessment that enumerates every personal-data category handled, its legal basis, retention, storage location, transfer regime, and the Article 25 mitigations in effect. Open-source libraries that do not themselves handle personal data defer the DPIA to the deployment that uses them.

The data-category inventory is enforced automatically. A CI check introspects the codebase and fails the build whenever the set of fields, storage keys, or audit-event keys drifts from the documented inventory. A change that introduces a new category cannot land without updating both the inventory and the DPIA in the same pull request.

Design principles applied throughout:

- **Data minimisation.** Sensitive values are redacted before leaving the caller's process wherever possible.
- **Non-reversible storage.** Credentials and identifiers are stored only as cryptographic digests; plaintext is never persisted.
- **EU residency.** Service deployments are hosted within the European Union.
- **Transport security.** TLS 1.2 / 1.3 only, with HSTS enforced.
- **No PII in logs or telemetry.** Enforced by review and by the error-handling conventions documented in the quality model.

9. Metrics and transparency

Headline metrics published per release:

Metric	Target
Lint and test pass on main	100 %
Unit + integration line coverage	≥ 90 %
Unwaived Medium-or-higher CVEs	0
ASVS Level 2 controls passed	Target 100 %; open gaps listed with remediation dates
ASVS Level 3 aspirational (auth + crypto)	Status recorded, gaps have remediation dates
Adversary chains closed, waived, or transferred	All
OpenSSF Scorecard	≥ 7.0
OpenSSF Best Practices badge	Silver on hardened repositories; rolling out family-wide
SLSA provenance level	≥ Build Level 3
Uptime (service, free tier)	≥ 99.5 % per month
Mean time to remediate critical security patch	≤ 7 days

These metrics are visible in release notes and in the public repository. A deterioration is triaged

into the risk register by policy (a manual step, not an automated one); the risk register is reviewed quarterly.

10. Continuous improvement

The SDLC framework itself has a roadmap. The following milestones are publicly committed:

- **Role separation.** Release signing, data-protection contact, and external security review separate into distinct roles as PRESIDIO scales beyond the current maintainer model.
- **Hermetic and reproducible builds.** SLSA Build Level 3 (hardened, isolated builds with non-forgable provenance) is in place; the next step is hermetic, byte-reproducible builds — a self-imposed stretch target, as SLSA defines no Build Level 4.
- **Fuzz and property-based testing.** Atheris harnesses now guard the security-critical parsers on the hardened flagship repositories; coverage is being extended across the rest of the family.
- **OpenSSF Best-Practices Badge.** Achieved at **silver** — first on the flagship `x402` (the repository the repeatable playbook was derived from), then on the hardening skill and the `ikigov-assess` and `arch-translucency` flagships — via that documented playbook; rollout to the remaining components and a gold-tier push are in progress.
- **Formal certification path.** SOC 2 at minimum, timed to a commercial-tier launch; ISO/IEC 27001 evaluated thereafter.

Progress against these milestones is reported at each quarterly governance review and reflected in the framework-alignment table published with each product release.

For questions about this report or the underlying framework, please use the security policy published with the product in question.